

AUDITORÍA RED TEAM

MY FILE SERVER 1

Presenta: Andrea Morúa Bravo
Docente: Mtro. Servando López Contreras
UPSLP

CONTEXTO DEL ENGAGEMENT

Nuestro objetivo es claro

Simular un ataque externo para medir la resiliencia operativa de la infraestructura.

El alcance de la evaluación

Máquina virtual My File Server 1 (IP: 192.168.56.103) dentro de un segmento de red controlado.

Esto ayudará a la empresa

A identificar brechas críticas antes de que actores maliciosos externos puedan explotarlas para comprometer la información institucional.

METODOLOGÍA APLICADA

- **1. Reconocimiento:** Localización de hosts activos y mapeo de red.
- **2. Enumeración:** Análisis de puertos, versiones de software y servicios expuestos.
- **3. Explotación:** Validación de vulnerabilidades para obtener el primer acceso.
- **4. Escalada de privilegios:** Ejecución de exploits orientados al kernel para control total (root).

NIVEL DE RIESGO

Crítico

La infraestructura presenta deficiencias graves de configuración y falta de actualización.

Un atacante externo con conocimientos **básicos** puede vulnerar el servidor en **menos de una hora**.

HALLAZGOS CRÍTICOS

FTP anónimo

Servicio vsftpd configurado con acceso público sin credenciales.

Credenciales expuestas

Archivo de texto plano (/readme.txt) en el servidor web revelando contraseñas críticas del sistema.

Falla de Kernel

Versión obsoleta de CentOS con la vulnerabilidad CVE-2016-5195 sin parchar.

IMPACTO EMPRESARIAL

CONFIDENCIALIDAD: FUGA DE CREDENCIALES, ARCHIVOS DE CONFIGURACIÓN Y DATOS INTERNOS SENSIBLES.

INTEGRIDAD (ALTA): RIESGO DE MODIFICACIÓN DE REGISTROS Y ALTERACIÓN DE BINARIOS DEL SISTEMA.

DISPONIBILIDAD (ALTA): INTERRUPCIÓN DELIBERADA DE LOS SERVICIOS CRÍTICOS DE RED ANTE UN CONTROL ABSOLUTO DEL ATACANTE.

MATRIZ DE RIESGO

ID	Vulnerabilidad	Impacto
01	FTP anónimo	Media
02	Credenciales web	Alta
03	Falla kernel DirtyCow	Crítica

RECOMENDACIONES ESTRATEGICAS

01

Hardening de servicios

Deshabilitar accesos anónimos en protocolos heredados (FTP/SMB).

02

Higiene web

Implementar revisiones de directorios y prohibir archivos de texto con credenciales.

03

Gestión proactiva de parches

Automatizar la actualización de núcleos de sistemas operativos.

ROADMAP DE REMEDIACIÓN

Inmediato (0-24 horas): Remover archivos temporales web y bloquear FTP anónimo.

Corto plazo (1-7 días): Aplicar parches de actualización del Kernel en servidores críticos.

Mediano plazo (30 días): Integrar escaneos de vulnerabilidades periódicos en el ciclo operativo.